DRAFT International Standard

ISO/IEC DIS 27090

Cybersecurity — Artificial Intelligence — Guidance for addressing security threats and failures in artificial intelligence systems

ICS: 35.030

ISO/IEC JTC **1**/SC **27**

Secretariat: **DIN**

Voting begins on:
2025-04-16

Voting terminates on:
2025-07-09

THIS DOCUMENT IS A DRAFT CIRCULATED FOR COMMENTS AND APPROVAL. IT IS THEREFORE SUBJECT TO CHANGE AND MAY NOT BE REFERRED TO AS AN INTERNATIONAL STANDARD UNTIL PUBLISHED AS SUCH.

IN ADDITION TO THEIR EVALUATION AS BEING ACCEPTABLE FOR INDUSTRIAL, TECHNOLOGICAL, COMMERCIAL AND USER PURPOSES, DRAFT INTERNATIONAL STANDARDS MAY ON OCCASION HAVE TO BE CONSIDERED IN THE LIGHT OF THEIR POTENTIAL TO BECOME STANDARDS TO WHICH REFERENCE MAY BE MADE IN NATIONAL REGULATIONS.

RECIPIENTS OF THIS DRAFT ARE INVITED TO SUBMIT, WITH THEIR COMMENTS, NOTIFICATION OF ANY RELEVANT PATENT RIGHTS OF WHICH THEY ARE AWARE AND TO PROVIDE SUPPORTING DOCUMENTATION.

This document is circulated as received from the committee secretariat.

Reference number
ISO/IEC DIS 27090:2025(en)

© ISO/IEC 2025



COPYRIGHT PROTECTED DOCUMENT

© ISO/IEC 2025

All rights reserved. Unless otherwise specified, or required in the context of its implementation, no part of this publication may be reproduced or utilized otherwise in any form or by any means, electronic or mechanical, including photocopying, or posting on the internet or an intranet, without prior written permission. Permission can be requested from either ISO at the address below or ISO's member body in the country of the requester.

ISO copyright office
CP 401 • Ch. de Blandonnet 8
CH-1214 Vernier, Geneva
Phone: +41 22 749 01 11
Email: copyright@iso.org
Website: www.iso.org

Published in Switzerland

Contents

Page

Foreword ..... **v**
Introduction ..... **vi**
1 Scope **1**
2 Normative references **1**
3 Terms and definitions **1**
4 Abbreviated terms **3**
5 Application of information security **4**
5.1 General 4
5.2 Zero trust principles 5
5.3 AI governance program 5
5.4 Applying software engineering best practices to AI 5
5.5 Supply chain management 6
5.6 Reduce impact by data limitation 6
5.6.1 General 6
5.6.2 Data minimization 7
5.6.3 Ensure allowed data 7
5.6.4 Minimal retention 7
5.6.5 Obfuscate data 7
5.6.6 Minimize open technical details 7
5.7 Controlling the effects of unwanted model behaviour during the operation stage 8
5.7.1 General 8
5.7.2 Oversight 8
5.7.3 Least model privilege 9
5.7.4 Transparency 9
5.7.5 Continuous validation 9
5.7.6 Explainability 9
5.7.7 Unwanted bias testing 10
5.8 Threat modelling 10
5.9 Red teaming 10
6 Threats to AI systems **10**
6.1 General 10
6.2 Data poisoning attack 11
6.2.1 Description 11
6.2.2 Failures resulting from data poisoning attacks 12
6.2.3 Detection of data poisoning attacks 13
6.2.4 Mitigation of data poisoning attacks 13
6.3 Evasion attack 15
6.3.1 Description 15
6.3.2 Failures resulting from evasion attacks 16
6.3.3 Detection of evasion attacks 16
6.3.4 Mitigation of evasion attacks 16
6.4 Membership inference 18
6.4.1 Description 18
6.4.2 Failures resulting from membership inference 18
6.4.3 Detection of membership inference 19
6.4.4 Mitigation of membership inference 19
6.5 Model exfiltration 19
6.5.1 Description 19
6.5.2 Failures resulting from model exfiltration 20
6.5.3 Detection of model exfiltration 20
6.5.4 Mitigation of model exfiltration 21
6.6 Model inversion 21
6.6.1 Description 21

© ISO/IEC 2025 – All rights reserved